

DOSSIER AVOCAT · validation juridique

AUDIT & PRÉPARATION

LEGAL REPORT — Application (nom commercial à finaliser)

Document interne — validation juridique requise avant diffusion ou signature · Généré le 15 août 2026

⚠ **Document indicatif.** Contenu produit par l'équipe produit à titre préparatoire ; il ne constitue pas un avis juridique. Seules les versions publiées in-app après validation avocat et complétion des données éditeur font foi.

Date : 2026-06-22

Auditeur : Expert Droit du Numérique + Conformité App Store (simulation)

Avertissement : Ce rapport est une analyse basée sur une lecture du code source et des pratiques déclarées. Il ne constitue pas un avis juridique. Consultez un avocat spécialisé avant toute mise en production mondiale.

TABLE DES MATIÈRES

1. [RGPD & Protection des données](#)
2. [Conditions d'utilisation YouTube](#)
3. [Conditions d'utilisation Spotify](#)
4. [Conformité App Store \(Apple\)](#)
5. [Conformité Google Play](#)
6. [Monétisation & Dons](#)
7. [Droits d'auteur & Contenu utilisateur](#)
8. [Protection des mineurs](#)
9. [Modération & Responsabilité éditeur](#)
10. [Matrice des risques juridiques](#)
11. [Plan de conformité](#)

1. RGPD & Protection des données

1.1 Ce qui est en place

Exigence RGPD	Implémentation	Statut
Consentement à l'inscription	<code>acceptTerms</code> + <code>termsVersion</code> requis à l'enregistrement	✓ Présent
Documents légaux accessibles	<code>/privacy</code> , <code>/terms</code> , <code>/legal/mentions</code> + <code>LegalDocumentView</code> in-app	✓ Présent
Droit d'accès	<code>GET /api/auth/me/export</code> — export des données utilisateur	✓ Présent
Droit à l'effacement	<code>DELETE /api/auth/account</code> — suppression de compte	✓ Présent
Politique de confidentialité	<code>app/src/content/legal/privacy.ts</code> , <code>rgpd.ts</code> , <code>dpa.ts</code> , <code>dpia.ts</code>	✓ Présent
Contrôle visibilité	<code>PrivacyVisibilityMenu.tsx</code> , ghost mode, localisation précision	✓ Présent
Cookies auth	<code>httpOnly</code> , <code>SameSite=Strict</code> — documenté comme nécessaire technique	✓ Présent
Données de localisation	<code>locationPrivacy.ts</code> — precision ajustable	✓ Partiel

1.2 Lacunes RGPD identifiées

LEG-RGPD-001 — CRITIQUE : Absence de bannière de cookies conforme

Description : L'application utilise des cookies `httpOnly` pour l'authentification. Bien que les cookies strictement nécessaires soient exemptés de consentement sous le RGPD, si des cookies analytics tiers, Stripe, ou autres sont présents, une bannière de consentement conforme (CMP) est obligatoire.

Références :

- RGPD Art. 6(1)(a) — consentement explicite pour cookies non nécessaires
- Directive ePrivacy 2002/58/CE — cookies
- Lignes directrices CNIL 2020 sur les cookies

Action requise : Auditer tous les cookies posés par l'application (Stripe.js, YouTube IFrame, analytics). Implémenter une CMP pour les non-essentiels.

LEG-RGPD-002 — ÉLEVÉ : Durée de conservation des données non définie dans le code

Description : Les documents légaux mentionnent des durées de conservation, mais aucune politique automatique de suppression (purge jobs) n'est visible dans le code. Les messages de chat, posts, stories expirées, données analytiques s'accumulent indéfiniment.

Références :

- RGPD Art. 5(1)(e) — limitation de la durée de conservation
- RGPD Art. 17 — droit à l'effacement

Action requise : Implémenter des jobs de suppression automatique : messages DM > 2 ans, analytics > 13 mois, stories expirées, comptes inactifs > 3 ans (avec notification préalable).

LEG-RGPD-003 — ÉLEVÉ : Localisation géographique des données en production

Description : PostgreSQL est déployé sur un VPS (onscen.com). Si le VPS est hors UE/EEE, tout transfert de données hors UE nécessite des clauses contractuelles types (CCT) ou un accord de transfert adéquat.

Références :

- RGPD Art. 44-49 — transferts vers pays tiers
- Schrems II (C-311/18, CJUE 2020)

Action requise : Vérifier la localisation du VPS. Si hors UE : documenter les CCT ou migrer vers un datacenter UE.

LEG-RGPD-004 — ÉLEVÉ : Cookies Stripe/YouTube intégrés sans consentement explicite

Description : L'intégration de [stripe-js](https://stripe.com/js) et de l'IFrame YouTube API injecte des cookies et trackers tiers qui peuvent opérer sans consentement préalable de l'utilisateur.

Références :

- RGPD Art. 26 — co-responsabilité de traitement
- Décision CNIL Google Analytics (janv. 2022)

LEG-RGPD-005 — MOYEN : DPIA (Data Protection Impact Assessment) présente mais complétude à vérifier

Description : dpia.ts existe dans les documents légaux. Vérifier qu'elle couvre les traitements haute intensité : géolocalisation en temps réel, live vidéo, données mineurs, profils musicaux.

LEG-RGPD-006 — MOYEN : Export données — format non structuré ?

Description : [GET /api/auth/me/export](https://api.auth.me/export) existe mais le format de l'export n'est pas auditable sans test live. Le RGPD exige un format "couramment utilisé et lisible par machine" (JSON ou CSV acceptable).

Action requise : Vérifier que l'export inclut : profil, posts, DMs, historique d'écoute, données financières (dons), données de géolocalisation.

LEG-RGPD-007 — MOYEN : Absence de DPO nommé (si > 250 salariés ou traitement systématique)

Description : Si la plateforme traite des données à grande échelle ou de manière systématique (géolocalisation en temps réel), la nomination d'un DPO est requise.

1.3 Points de conformité RGPD : synthèse

Article RGPD	Conformité	Note
Art. 5 — Principes	⚠ Partiel	Durée de conservation non implémentée
Art. 6 — Licéité	✅ Partiel	Consentement inscription OK
Art. 7 — Consentement	⚠ Partiel	Cookies tiers sans CMP
Art. 13/14 — Information	✅	Documents légaux présents
Art. 17 — Effacement	✅	DELETE /account présent
Art. 20 — Portabilité	⚠	Export présent mais format à vérifier
Art. 25 — Privacy by design	⚠ Partiel	Quelques contrôles, localisation granulaire
Art. 32 — Sécurité	✅ Bon	JWT httpOnly, bcrypt, chiffrement
Art. 35 — DPIA	⚠	DPIA présente, complétude à vérifier
Art. 44-49 — Transferts	?	Dépend localisation VPS

2. Conditions d'utilisation YouTube**2.1 Références officielles**

- **YouTube API Services Terms of Service** : <https://developers.google.com/youtube/terms/api-services-terms-of-service>
- **YouTube Terms of Service** : <https://www.youtube.com/t/terms>
- **YouTube API Services Developer Policies** : <https://developers.google.com/youtube/terms/developer-policies>
- **YouTube Branding Guidelines** : <https://www.youtube.com/howyoutubeworks/our-commitments/sharing-revenue/>

2.2 Ce qui est autorisé

Usage	Clause	Conformité
Embed via IFrame API	YouTube API Terms §1	✓ Autorisé
Recherche via Data API v3	YouTube API Terms §1	✓ Autorisé
Récupération playlists via API	YouTube API Terms §1	✓ Autorisé
Cache résultats API ≤ 24h	YouTube API Developer Policies §III.E	✓ Autorisé (respecté : 1h)
Affichage "Watch on YouTube" link	Branding Guidelines	✓ Requis et conforme
oEmbed pour métadonnées	Non restreint (HTTP public)	✓ Autorisé
Authentification YouTube OAuth (playlists user)	OAuth 2.0 standard	✓ Autorisé

2.3 Ce qui est interdit

Usage	Clause	Statut plateforme
Téléchargement de contenu YouTube	YouTube TOS §6, API Terms §4.H	✓ Non implémenté
Contournement du lecteur natif pour lire l'audio	YouTube API Terms §4.I	✓ Non implémenté
Affichage de vidéos sans interface YouTube standard	YouTube API Terms §4.C	✓ IFrame standard utilisé
Stockage de données API > 24h	YouTube API Developer Policies §III.E	✓ Cache 1h
Utilisation de l'API pour scénariser de la publicité	YouTube API Terms §4.B	⚠ Voir §2.4

2.4 Zones grises — RISQUE JURIDIQUE

LEG-YT-001 — CRITIQUE : Synchronisation YouTube multi-utilisateurs

Description : Les salons de l'application synchronisent la lecture d'une vidéo YouTube entre plusieurs utilisateurs via l'IFrame API. Chaque utilisateur voit son propre lecteur, mais le playback est coordonné.

Analyse :

- YouTube TOS §6 : "limited, non-exclusive, non-transferable licence to access and use the Service"
- YouTube API Terms §4.F : "you must not use the YouTube API Services to create or enable others to create Content that..."

Ce qui est PROBABLEMENT autorisé : chaque utilisateur charge sa propre instance IFrame. La synchronisation est côté client, pas un re-streaming.

Ce qui est RISQUÉ : créer un contexte de "visionnage en groupe commercial" sans accord YouTube. Des services comme Watch2Gether ont des Conditions d'utilisation YouTube explicitement négociées.

Recommandation : Contact avec Google/YouTube partner program. Envisager un accord commercial explicite.

LEG-YT-002 — ÉLEVÉ : Publicités sponsor affichées dans les salons YouTube

Description : L'application affiche des bannières publicitaires sponsor (`SalonAdBanner.tsx`) dans des salons où du contenu YouTube est joué.

Clause YouTube API Terms §4.B : "You must not sell advertising, sponsorships, or promotions placed within or alongside YouTube API Services or YouTube API data, unless you obtain prior written consent from YouTube."

Impact : Violation directe des YouTube API Terms si des revenus publicitaires sont générés autour du contenu YouTube.

Action requise :

- Option A : Retirer les publicités sponsor des salons affichant du contenu YouTube
- Option B : Obtenir un accord écrit de YouTube (difficile pour les petites plateformes)
- Option C : Séparation technique entre les vues YouTube et les placements pub

LEG-YT-003 — ÉLEVÉ : `ALLOW_YOUTUBE_REMOTE_FALLBACK` — scraping YouTube

Description : Cette variable active un fallback de recherche YouTube non officiel (scraping/undocumented API).

YouTube TOS §4.H : "You agree that you will not access, reproduce, download, distribute, transmit, broadcast, display, sell, license, alter, modify or otherwise use any part of the Service or any Content except: (a) as expressly authorized by the Service; or (b) with prior written permission from YouTube..."

Impact : Violation caractérisée des TOS YouTube. Risque de ban API key, voire de poursuite.

Action requise : Ne JAMAIS activer en production. Supprimer la fonctionnalité ou la documenter comme dev-only avec des gardes forts.

LEG-YT-004 — MOYEN : Quota YouTube Data API (10 000 unités/jour)

Description : La limite de quota gratuite est insuffisante pour une application avec des milliers d'utilisateurs actifs.

Clause : Les dépassements de quota sans accord commercial peuvent entraîner la suspension de la clé API.

Action requise : Demander une augmentation de quota via Google Cloud Console. Documenter l'usage dans la candidature.

2.5 Ce qui doit être modifié (YouTube)

Priorité	Action	Délai
● Critique	Retirer les pubs sponsor des salons YouTube OU obtenir accord YouTube	Immédiat
● Critique	Supprimer/protéger <code>ALLOW_YOUTUBE_REMOTE_FALLBACK</code>	Immédiat
● Élevé	Demander augmentation quota YouTube API	1 semaine
● Élevé	Clarifier légalement la synchronisation multi-users avec un avocat	1 mois
● Moyen	Envisager un contact/partenariat YouTube	3 mois

3. Conditions d'utilisation Spotify

Statut (2026-07) : intégration Spotify **retirée** du produit (MODIF 662+). Cette section est conservée comme archive juridique ; aucun code ni variable d'environnement Spotify actifs.

3.1 Références

- **Spotify Developer Policy** : <https://developer.spotify.com/policy>
- **Spotify Design Guidelines** : <https://developer.spotify.com/documentation/design-and-branding>

3.2 Analyse

Usage	Conformité
OAuth Spotify (playlists, lecture)	✓ Autorisé via scopes légitimes
<code>PoweredBySpotify.tsx</code> — attribution	✓ Requis et présent
<code>SpotifySalonDeprecatedNotice.tsx</code>	✓ Indication de deprecation
Contrôle lecture Spotify in-salon	⚠ Voir LEG-SP-001
Spotify Jam integration (<code>spotifyJam.ts</code>)	⚠ Voir LEG-SP-002

LEG-SP-001 — ÉLEVÉ : Contrôle de lecture Spotify dans les salons

Description : L'API Spotify permet le contrôle de lecture via `POST /me/player/...` pour l'utilisateur authentifié. la plateforme permet à d'autres membres du salon de contrôler la lecture Spotify d'un utilisateur.

Spotify Developer Policy §2 : "do not let other third-party services or applications control the playback of a user's Spotify account without their explicit consent."

Analyse : Si le host a explicitement autorisé le contrôle (acceptation explicite in-app), c'est probablement conforme. Mais si d'autres membres peuvent modifier la lecture sans consentement explicite, c'est une violation.

Action requise : Vérifier que seul le host peut contrôler sa propre lecture Spotify, avec consentement explicite.

LEG-SP-002 — MOYEN : Spotify Jam (listening session partagée)

Description : `spotifyJam.ts` implémente une session d'écoute partagée. Vérifier que cela utilise l'API Spotify officielle "Spotify Group Session" (feature Beta) ou une implémentation non officielle.

Action requise : S'assurer que l'implémentation utilise uniquement les APIs Spotify officielles dans leurs scopes autorisés.

LEG-SP-003 — FAIBLE : `SpotifySalonDeprecatedNotice`

Description : Un composant de dépréciation Spotify dans les salons existe. Cela suggère que la plateforme a eu des problèmes de conformité Spotify par le passé et a dépréqué cette fonctionnalité. C'est une bonne pratique.

4. Conformité App Store (Apple)

4.1 Références

- **App Store Review Guidelines :** <https://developer.apple.com/app-store/review/guidelines/>
- **Apple Human Interface Guidelines :** <https://developer.apple.com/design/human-interface-guidelines/>

4.2 Analyse

Règle	Statut plateforme
2.1 App Completeness	✓ Application fonctionnelle
2.3.3 Metadata — Pas de screenshots trompeurs	À vérifier
3.1.1 In-App Purchase — Achats in-app via IAP Apple	⚠ CRITIQUE
3.2.1 Acceptable — Dons/tips créateurs	⚠ Voir §4.3
4.1 Copyrights — Contenu utilisateur	⚠ Voir §7
4.3 Spam — Applications dupliquées	✓
5.1 Privacy — Politique de confidentialité requise	✓ Présente
5.1.1 Data Collection	⚠ App Privacy labels requis
5.1.2 Data Use and Sharing	⚠ À vérifier
5.4 Push Notifications — Consentement requis	✓ <code>useWebPushRegistration</code>

LEG-AS-001 — CRITIQUE : In-App Purchases et Stripe

Apple App Store Guidelines §3.1.1 : "If you want to unlock features or functionality within your app, you must use in-app purchase."

Problème : Les abonnements créateurs (`CreatorSubscribeSheet`) et les plateformes plans (`PlatformSubscriptionPage`) utilisent Stripe, pas Apple IAP.

Impact : Rejet de l'application par Apple si les achats numériques ne passent pas par Apple IAP (30% de commission Apple).

Exceptions notables :

- Les dons/tips directs à des créateurs peuvent être exemptés (Rule 3.2.1(ii) — "tips for content")
- Les "Reader apps" ont une exemption (mais la plateforme n'est pas un Reader app)

Action requise :

- Option A : Implémenter Apple IAP pour les abonnements et plans en natif iOS
- Option B : Désactiver les achats dans l'app iOS (modèle "Reader app") et rediriger vers le web
- Option C : Obtenir une exemption explicite (très difficile)

LEG-AS-002 — ÉLEVÉ : App Privacy Labels (App Store Connect)

Description : Depuis iOS 14.3 (déc. 2020), Apple exige des "App Privacy Labels" dans App Store Connect décrivant précisément les données collectées.

Données collectées par la plateforme à déclarer :

- Localisation (géolocalisation temps réel)
- Contenu utilisateur (messages, reels, compositions)
- Historique de navigation (feed, salons visités)
- Identifiants (User ID, Device ID)
- Données financières (dons, abonnements)
- Infos contact (email, nom)
- Données d'utilisation (analytics)

Action requise : Remplir les App Privacy Labels dans App Store Connect avec précision.

LEG-AS-003 — MOYEN : Live streaming — règles de contenu

Apple Guidelines §1.2 (User Generated Content) : Applications permettant du contenu généré par les utilisateurs (UGC) doivent avoir :

- Des mécanismes de filtrage de contenus offensants
- Un système de signalement
- La capacité de bloquer des utilisateurs
- Un processus de modération

Statut plateforme :

-  Système de signalement (`ReportContentModal`)
-  Blocage utilisateurs
-  Modération admin
-  Pas de filtrage automatique (IA) des contenus live
-  Pas de filtre de contenu offensant pour les descriptions de lives/salons

5. Conformité Google Play

5.1 Références

- **Google Play Developer Policies :** <https://play.google.com/about/developer-content-policy/>
- **Google Play Billing Library :** <https://developer.android.com/google/play/billing>

5.2 Analyse

Règle	Statut
Payments Policy — achats via Play Billing	⚠️ CRITIQUE (même problème qu'Apple)
User Generated Content — modération	⚠️ Partiel
Data Safety — déclaration requise	⚠️ À compléter
Privacy Policy	✅ Présente
Dangerous Permissions — caméra, micro	✅ Justifiés pour les lives
Impersonation	✅ Non applicable
Intellectual Property	⚠️ Voir §7

LEG-GP-001 — CRITIQUE : Google Play Billing pour achats in-app

Même problème qu'Apple : Google Play exige que les achats d'items numériques passent par Google Play Billing (30% commission). Stripe seul n'est pas accepté pour les achats numériques.

Exception Google (juin 2022) : Google autorise des systèmes de paiement alternatifs dans certains pays/cas, mais avec des exigences de déclaration strictes.

Action requise : Même approche qu'Apple IAP (voir LEG-AS-001).

LEG-GP-002 — ÉLEVÉ : Data Safety Section

Description : Google Play exige une "Data Safety Section" déclarant les données collectées, partagées, et leur usage.

Action requise : Remplir la Data Safety Section dans Google Play Console (même scope que les App Privacy Labels Apple).

6. Monétisation & Dons

6.1 Régulation des dons en ligne (France/UE)

Aspect	Analyse
Dons ponctuels	✅ Légaux sans licence de collecte (sauf association)
Abonnements créateurs	✅ Légaux (contrat commercial)
Cadeaux virtuels convertibles	⚠️ Voir §6.2
Stripe Connect	✅ KYC délégué à Stripe
TVA sur les services numériques	⚠️ Voir §6.3

LEG-MON-001 — ÉLEVÉ : Cadeaux virtuels et conversion en argent réel

Description : Le système de cadeaux virtuels (`gift_sent` , `gifts.ts` , `LiveGiftOverlay`) — si les cadeaux peuvent être convertis en argent réel par les créateurs, cela peut constituer un système de "tokens" ou de "monnaie virtuelle" soumis à réglementation.

Réglementation applicable :

- En France : si conversion possible → potentiellement soumis à la réglementation des prestataires de services de paiement (PSP — Directive PSD2)
- AMLD5 (Anti-Money Laundering) : si tokens > certains seuils

Action requise : Vérifier si les cadeaux sont purement symboliques (pas de valeur monétaire) ou convertibles. Si convertibles, consulter un expert en réglementation financière.

LEG-MON-002 — MOYEN : TVA sur les services numériques UE

Description : Les abonnements et dons via Stripe sont soumis à la TVA du pays de l'acheteur (règle OSS post-2021).

Action requise : Vérifier que Stripe Tax est activé, ou que la TVA est correctement calculée et déclarée pour tous les pays UE.

LEG-MON-003 — MOYEN : Stripe Connect — obligations KYC des créateurs

Description : Les créateurs qui reçoivent des dons via Stripe Connect doivent passer le KYC Stripe (vérification d'identité). Si la plateforme ne valide pas que le créateur a complété son KYC avant de recevoir des paiements, Stripe peut bloquer les paiements et la plateforme peut être considérée comme facilitateur de paiement non régulé.

Statut : `LiveStripeConnectGate.tsx` semble gérer cette vérification. À confirmer end-to-end.

7. Droits d'auteur & Contenu utilisateur

7.1 UGC (User Generated Content)

Statut plateforme :

- Compositions audio uploadées par les utilisateurs
- Reels vidéo (potentiellement avec de la musique copyrightée)
- Stories avec musique (`StoryMusicPicker`)
- Lives avec audio ambient
- Posts et commentaires

LEG-DR-001 — CRITIQUE : Absence de Content ID / DMCA automatisé pour les reels

Description : Les reels vidéo peuvent contenir de la musique copyrightée. Sans système de détection automatique (Content ID comme YouTube, ou Audible Magic comme TikTok), la plateforme s'expose à des notifications DMCA.

Réglementation :

- DMCA §512 (USA) — safe harbor conditionné à un système de notice-and-takedown
- DSA (Digital Services Act — UE, applicable depuis août 2023 pour les grandes plateformes, 2024 pour toutes)
- Article 17 DSAT (anciennement Art. 13) — obligation de filtrage pour les plateformes UGC

Action requise :

- Implémenter un processus DMCA/Notice & Takedown documenté
- À terme : intégrer un service de détection audio (ACRCloud, Gracenote, ou similaire)

LEG-DR-002 — ÉLEVÉ : Musique dans les stories

Description : `StoryMusicPicker.tsx` permet d'ajouter de la musique aux stories. Si cette musique est copyrightée et publiée, c'est une violation des droits de l'auteur/compositeur.

Action requise : Limiter la bibliothèque musicale des stories à :

- Musique libre de droits (Creative Commons)
- Partenariats avec des distributeurs (comme Instagram a avec certains labels)
- Musique de la bibliothèque de l'utilisateur (si Spotify/Apple Music)

LEG-DR-003 — MOYEN : Licence sur les contenus uploadés

Description : Les CGU doivent inclure une licence explicite que l'utilisateur accorde à la plateforme pour utiliser, héberger, afficher ses contenus.

Action requise : Vérifier que les CGU (`terms.ts`) incluent une clause de licence UGC explicite.

7.2 Droits voisins YouTube

L'IFrame API YouTube affiche les vidéos avec leurs publicités et DRM intacts. Les droits sont gérés par YouTube. La plateforme n'est pas responsable du contenu des vidéos YouTube embedées (sous réserve du bon usage de l'API).

8. Protection des mineurs

8.1 Implémentation actuelle

Mesure	Statut
Âge minimum profil : 13 ans (<code>MIN_PROFILE_AGE</code>)	✓
Âge minimum live : 16 ans (<code>MIN_LIVE_AGE</code>)	✓
Âge minimum monétisation : 18 ans (<code>CREATOR_MONETIZATION_MIN_AGE</code>)	✓
<code>BirthDateInput.tsx</code> à l'inscription	✓
Acceptation des conditions live (<code>LiveLegalAcceptanceModal</code>)	✓

8.2 Lacunes

LEG-MIN-001 — CRITIQUE : Vérification d'âge basée sur déclaration uniquement

Description : La date de naissance est saisie par l'utilisateur sans vérification (pas de pièce d'identité, pas de vérification parentale pour les 13-15 ans).

Réglementation :

- RGPD Art. 8 — consentement parental requis pour les enfants < 16 ans (seuil FR : 15 ans per CNIL)
- DSA 2022 — exigences renforcées de protection des mineurs
- Children's Online Privacy Protection Act (COPPA, USA) — si expansion US

Action requise :

- Vérification parentale pour les 13-15 ans (email parental)
- Ou relever l'âge minimum à 16 ans
- Documenter clairement la politique dans les CGU

LEG-MIN-002 — ÉLEVÉ : Contenus adult-only potentiels sur les lives

Description : Les lives peuvent présenter des contenus potentiellement inappropriés pour les mineurs (sans filtre ou restriction d'accès basé sur l'âge réel du spectateur).

Action require : Implémenter un système de catégorisation des lives (ex: live 18+ avec restriction explicite).

9. Modération & Responsabilité éditeur

9.1 Digital Services Act (DSA) — UE

Applicable à la plateforme : Oui, dès lors qu'elle opère dans l'UE.

Obligation DSA	Statut
Signalement de contenus illicites	✓ <code>ReportContentModal</code>
Réponse aux injonctions judiciaires	? Processus non documenté dans le code
Transparence des publicités	⚠ Sponsors non identifiés explicitement
Algorithme de recommandation	? <code>reelFeedAlgorithm.ts</code> — transparence ?
Point de contact DSA	✗ Pas visible dans les documents légaux
Rapport de transparence annuel (si > 45M users)	N/A (taille actuelle)
Coordonnateur national des services numériques	✗ Contact non documenté

LEG-DSA-001 — ÉLEVÉ : Pas de point de contact DSA

Action require : Ajouter dans les mentions légales un point de contact désigné pour les autorités compétentes (Art. 11 DSA).

LEG-DSA-002 — MOYEN : Transparence publicité

Description : Les publicités sponsor (`SalonAdBanner` , `MapAdBanner` , `ReelsSponsoredSlide`) doivent être clairement identifiées comme "Publicité" ou "Sponsorisé" (DSA Art. 26).

Statut : Vérifier que les composants de pub affichent un label explicite. `SalonAdBanner.tsx` et similaires doivent afficher "Annonce" ou "Sponsorisé".

9.2 Responsabilité plateforme (France)

- **Loi de confiance dans l'économie numérique (LCEN) :** La plateforme est un hébergeur au sens de l'Art. 6 — responsabilité limitée si prompt retrait des contenus signalés.
- **Condition :** Réactivité dans la modération des signalements (idéalement < 24h pour contenus graves, < 7 jours pour autres).

10. Matrice des risques juridiques

Critique

#	Risque	Domaine	Impact potentiel
1	Publicités dans les salons YouTube	YouTube TOS §4.B	Suspension clé API + poursuite
2	Achats numériques sans Apple IAP / Google Play Billing	App Store §3.1.1	Rejet app store + amendes
3	<code>ALLOW_YOUTUBE_REMOTE_FALLBACK</code> activé en prod	YouTube TOS §4.H	Suspension API + violation contractuelle
4	Contenu copyrighted dans les reels sans DMCA	DMCA §512 / DSA	Mises en demeure, amendes, blocage

Élevé

#	Risque	Domaine
5	Synchronisation YouTube multi-users = zone grise	YouTube API Terms
6	Cadeaux virtuels convertibles sans régulation PSP	PSD2 / AMLD5
7	Vérification d'âge déclarative uniquement	RGPD Art. 8 / DSA
8	Pas de CMP pour cookies tiers (Stripe, YouTube)	RGPD Art. 6 / ePrivacy
9	Données personnelles stockées hors UE potentiellement	RGPD Art. 44-49
10	Contrôle Spotify par des tiers sans consentement	Spotify Developer Policy
11	Musique copyrightée dans les stories	Droits voisins / DMCA
12	Données non supprimées automatiquement (durée conservation)	RGPD Art. 5(1)(e)
13	Pas de Data Safety Google Play / App Privacy Labels Apple	Store policies

Moyen ●

#	Risque	Domaine
14	TVA services numériques UE non vérifiée	TVA OSS
15	Pas de point de contact DSA dans les mentions	DSA Art. 11
16	Transparence algorithme recommandation	DSA Art. 27
17	Licence UGC non explicite dans les CGU	Droit d'auteur
18	Export données RGPD — format/complétude à vérifier	RGPD Art. 20
19	Publicités non labellisées "Sponsorisé"	DSA Art. 26
20	KYC créateurs Stripe non bloquant avant paiements	PSD2

Faible ●

#	Risque	Domaine
21	Mentions légales éditeur à compléter (LCEN)	LCEN
22	DPIA complétude à vérifier	RGPD Art. 35

11. Plan de conformité

Priorité immédiate (avant tout lancement public)

SEMAINE 1-2 :

- Retirer les publicités sponsor des salons YouTube (LEG-YT-002)
- Protéger/supprimer ALLOW_YOUTUBE_REMOTE_FALLBACK (LEG-YT-003)
- Implémenter CMP (bannière cookies) pour Stripe/YouTube (LEG-RGPD-001)
- Vérifier la géolocalisation du VPS (LEG-RGPD-003)

SEMAINE 3-4 :

- Contacter un avocat spécialisé TOS YouTube pour la synchronisation
- Implémenter Apple IAP ou désactiver achats sur iOS (LEG-AS-001)
- Implémenter Google Play Billing ou désactiver achats sur Android (LEG-GP-001)
- Ajouter point de contact DSA dans les mentions légales (LEG-DSA-001)

MOIS 2 :

- Implémenter purge automatique données (durée de conservation) (LEG-RGPD-002)
- Labelliser "Sponsorisé" toutes les publicités (LEG-DSA-002)
- Mettre en place un processus DMCA Notice & Takedown documenté (LEG-DR-001)
- Remplir App Privacy Labels (Apple) + Data Safety (Google) (LEG-AS-002, LEG-GP-002)

MOIS 3 :

- Vérifier la musique dans les stories – licence ou restriction (LEG-DR-002)
- Renforcer la vérification d'âge (consentement parental 13-15 ans) (LEG-MIN-001)
- Consulter expert réglementation financière pour les cadeaux virtuels (LEG-MON-001)
- Vérifier TVA OSS / Stripe Tax (LEG-MON-002)
- Revoir la licence UGC dans les CGU (LEG-DR-003)

Ce rapport doit être revu par un avocat spécialisé en droit du numérique avant de servir de base à des décisions juridiques.

Rapport généré le 2026-06-22.